Shadow AI: governança do uso de IA

Como identificar práticas declaradas, lacunas e informações a confirmar no uso de ferramentas de inteligência artificial.

Material genérico. Não usa respostas ou dados de qualquer pessoa ou empresa. Não é diagnóstico, auditoria, certificação, declaração de conformidade ou benchmark, e não é personalizado a partir das suas respostas.

O que o tema significa

Shadow AI é o uso de ferramentas de IA por pessoas ou equipes sem que a organização as conheça, as tenha aprovado ou as tenha orientado. Esse uso pode envolver dados que não deveriam sair da organização e fornecedores sem avaliação prévia.

O NIST AI Risk Management Framework 1.0 (NIST AI 100-1) é um referencial de uso voluntário para gerenciar riscos de sistemas de IA. Seu núcleo se organiza em quatro funções: GOVERN, MAP, MEASURE e MANAGE. A função GOVERN trata de políticas, papéis e responsabilidades, e de inventário de sistemas de IA.

Método da ferramenta

ADAPTAÇÃO ROOT TRUST Autoavaliação educativa com cinco temas. Cada tema recebe uma das respostas: Sim, Parcialmente, Não ou Não sei.

- **Regras:** existem regras conhecidas para o uso de IA no trabalho.
- **Visibilidade:** a organização conhece as ferramentas de IA usadas pela equipe.
- **Dados sensíveis:** há orientações e controles para evitar envio indevido de dados sensíveis à IA.
- **Fornecedores:** ferramentas e fornecedores de IA são avaliados antes da adoção.
- **Equipe:** a equipe recebe orientação prática sobre o uso responsável de IA.

A ferramenta não atribui nota, pontuação, percentual ou classificação de risco. “Sim” indica uma prática declarada, cuja implementação e eficácia não são verificadas. “Não sei” não é prova de ausência de controle. “Parcialmente” e “Não” recebem uma ação curta de melhoria; “Não sei” recebe um passo para confirmar a situação com os responsáveis.

Limites

- A ferramenta não inspeciona sistemas, não detecta ferramentas automaticamente e não verifica o que foi declarado.
- Cinco respostas “Sim” não comprovam segurança. Cinco respostas “Não sei” não comprovam falta de controle.
- Não substitui avaliação jurídica sobre tratamento de dados nem verificação de conformidade com a legislação aplicável.
- Segundo o NIST AIRC, o AI RMF está em revisão. Antes de usar o referencial em decisões formais, confirme a versão vigente.

Próximos passos

1. Montar um inventário das ferramentas de IA usadas, com responsável, finalidade e tipo de dado tratado.
2. Definir regras de uso aprovadas pela liderança: usos permitidos, usos proibidos e responsáveis por dúvidas.
3. Classificar os tipos de dado da organização e definir quais podem ser enviados a ferramentas de IA, com apoio jurídico quando envolver dados pessoais.
4. Avaliar fornecedores antes da adoção: tratamento de dados, retenção, controle de acesso e condições contratuais.
5. Orientar a equipe com exemplos práticos sobre dados, conferência das saídas da IA e canal de dúvidas.
6. Revisar o inventário e as regras periodicamente, principalmente quando surgirem novas ferramentas.

Perguntas de revisão

- Quem na organização pode dizer quais ferramentas de IA estão em uso hoje?
- Existe uma regra escrita sobre o uso de IA no trabalho, e as pessoas sabem onde encontrá-la?
- Os tipos de dado que não podem ser enviados a ferramentas de IA estão definidos e são conhecidos pela equipe?
- Há um responsável por avaliar uma ferramenta ou fornecedor de IA antes de adotá-lo?
- A equipe sabe a quem recorrer em caso de dúvida sobre um uso específico?
- Com que frequência o inventário e as regras são revisados?

Ações por tema

- Reunir os responsáveis de cada área para listar as ferramentas de IA conhecidas e as dúvidas em aberto (respostas “Não sei”).
- Redigir uma versão curta das regras de uso, com exemplos de usos permitidos e proibidos, e submetê-la à liderança.
- Definir um fluxo simples de avaliação para novas ferramentas ou fornecedores, com os critérios e o responsável pela decisão.
- Marcar uma data para rever o inventário e as regras, e para confirmar a versão vigente do referencial adotado.

Fontes consultadas

- **REFERÊNCIA OFICIAL** NIST. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1. nist.gov/itl/ai-risk-management-framework
- **REFERÊNCIA OFICIAL** NIST AIRC. Núcleo do AI RMF: funções GOVERN, MAP, MEASURE e MANAGE e subcategorias GOVERN 1.1, 1.6, 2.1 e 6.1. airc.nist.gov/airmf-resources/airmf/5-sec-core

Consultadas em 12/10/2026. O checklist é uma adaptação educativa, não um checklist oficial do NIST.

Solicitar diagnóstico

No site da Root Trust, use o formulário “Solicitar diagnóstico” (Nome, Empresa e WhatsApp). A conversa inicial é gratuita e de qualificação, com retorno por ligação ou WhatsApp no próximo dia útil após o recebimento do pedido. Se preferir, escreva para contato@roottrust.com.br. Não é auditoria, não há agenda automática e não inclui relatório personalizado.